# SecurePass Telecom için Yapılan İnceleme Notlarım

# SecurePass Telecom

Güvence vermişler

Parola politikaları -
Ayrıcalıklı hesaplar -
MFA kritik hesaplarda aktif -
Servis hesapları güvenli yönetiliyor -
Kullanılmayan hesap yokmuş ?-
Eski çalışan hesapları kaldırılmış -
Domain Admin yetkileri minimum seviyedeymiş(yani erişim açısından)-
Kimlik doğrulama logalrı düzenli inceleniyormuş -
Hash algoritmaları güvenliymiş ? -
Kerberos yapılandırmaları güvenliymiş -

users.csv dosyasına göre
oldadmin hesabı disabled ancak kullanılmayan hesap yok  beyanında bulunmuşlardı.
Intern 2024 hesabı neden disabled değil ? 2 yıldır hala stajyer mi ?
tempconsultant dışardan olan bir hesap ayrıcalıkları çok çok dikkatli verilmelidir.

password_policy.txt dosyasına göre
Complexity required kısmının inaktif olması “sektör standardına” uygun değil
Lockout threshold kısmı 0 olduğu için saldırgan brute force ile sınırsız deneme yapabilir
Lockout duration 0 olduğu için sistem yanlış şifrelemede bekleme yapmaz brute force ile beklemeden deneme yapabilir
Store password using reversible encryption ile geri çözülebilir şifre kullanımına izin veriliyor hashlenmeden düz metin olarak saklanması yine yüksek bir risktir ve kesinlikle sektör standartlarına uygun değildir.

mfa_report.csv dosyasına göre
administrator,domainadmin,backupsvc,sqlsvc ve tempconsultant MFA ‘ya tabi tutulmamıştır.Hepsi büyük güvenlik açığıdır.Özellikle external serviceler için enable edilmelidir.

service_accounts.csv dosyasına göre
backupsvc sqlsvc legacysvc hesaplarının son parola değişimleri yıllar önce olup diğer applinksvc ve syncsvc hesaplarının parola değişimi hiç olmamıştır.

privileged_accounts.csv dosyasına göre

users.csv dosyasında backupsvc sqlsvc hesapları “service” olarak görünmektedir ama burada ayrıcalıklı hesap olarak görünmektedir.administrator hesabıda built in olarak görünmektedir.

privileged_review.txt dosyasına göre
administrator,domainadmin,backupsvc hesaplarının Owner’ı bilinmemektedir.Accountability için bu çok mühimdir.

login_audit.log dosyasına göre
2026-03-01 tarihinde admin girişi 2 farklı (10.10.10.5 ve 185.22.44.8) ip’den yapılmıştır. Aynı tarihte aynı ip (103.81.25.11) helpdesk, administrator, backupsvc ve sqlsvc girişi yapmıştır.

HASHLER
ntlm_hashes.txt dosyasında bulunanlar:
administrator şifresi:
domainadmin şifresi: Password123
backupsvc:123456
helpdesk:password

md5_hashes.txt dosyasında bulunanlar:
admin: password
developer: 123456
backupsvc:letmein
helpdesk:admin
finance:123456789

sha256_hashes.txt dosyasında bulunanlar:
finance.manager:password123

kerberoast_hashes.txt dosyasında hashler tam verilmemiştir.Verilenler kanıt niteliği taşımaz
spn_accounts.txtye göre
http/intranet.securepass.localwebsvc http olması bir zafiyet mi ?
http/legacy.securepass.locallegacysvc

asrep_hashes.txt dosyasında hashler tam verilmemiştir.Verilenler kanıt niteliği taşımaz

asrep_users.txt dosyasına göre
legacyuser,oldadmin,migrationaccount kullanıcıları bulunmuştur ? Silinmemişler ve tanımlı değillerdi yukarıda ?? Ayrıca tempconsultant için mfa yok ve burada yetkili.

domain_admins.txt dosyasına göre

administrator ve domainadmin var (biri yeterli bence ama hadi 2 olsun) yinede backupsvc helpdesk sqlsvc helpdesk ve tempconsultantın hepsinin burada olması bir risk oluşturuyor.

leaver_accounts.csv dosyasına göre

oldadmin en son 532 gün önce giriş yapmasına rağmen (yani silinmesi gerekirken) hala usersta var.Intern hala devam etmediği bu dosyada kanıtlandı en son 680 gün önce giriş yapmış ama hala sistemden silinmemiş.legacyuser de aynı şekilde 881 gün önce giriş yapmış en son ve hala silinmemiş.